



Privilege Escalation Recon Report

Target System: Windows (Victim Machine)

Tool Used: winPEASany.exe

Execution Method: SMB share from Kali Linux host

Date: October 1, 2025

Analyst: Alex



Objective

To identify potential privilege escalation vectors on a Windows system using winPEAS, executed remotely via an SMB share.



Key Findings

1. Hidden Directories in User Profiles

- Detected hidden or system-level folders under C:\Users, including:
- Default User, Default, All Users
- Temporary files in AppData\Local\Temp, such as:
- edge_BITS_2580_129628787\BIT1D43.tmp

These may contain residual data or misconfigured permissions worth investigating further.

2. Executable Files with Insecure Permissions

- Multiple .pyd files (Python dynamic libraries) located in:
- C:\Users\Alley\AppData\Roaming\Python\Python38\site-packages\win32\
- C:\Users\Alley\AppData\Local\Programs\Python\Python38\lib\site-packages\win32\

These files are writable by the user Alley and Interactive, both with AllAccess permissions. If loaded by privileged processes, they could be hijacked for code injection.

3. Writable Executable in Shared Folder

- C:\Shared\WinPEASany.exe is writable by Authenticated Users:
- Permissions: WriteData/CreateFiles

This presents a direct opportunity to replace the binary with a malicious payload if executed by a higher-privilege user or service.



Recommendations

- Investigate Execution Contexts: Determine if any of the writable .pyd files or winPEASany.exe are executed by SYSTEM or Admin-level processes.
- Replace Vulnerable Executables: Craft and deploy a payload to replace winPEASany.exe if safe to do so.
- Monitor for Scheduled Tasks or Services: Look for any that reference these paths and test for privilege escalation.
- Consider Obfuscation or In-Memory Execution: To bypass AV or SmartScreen blocks.



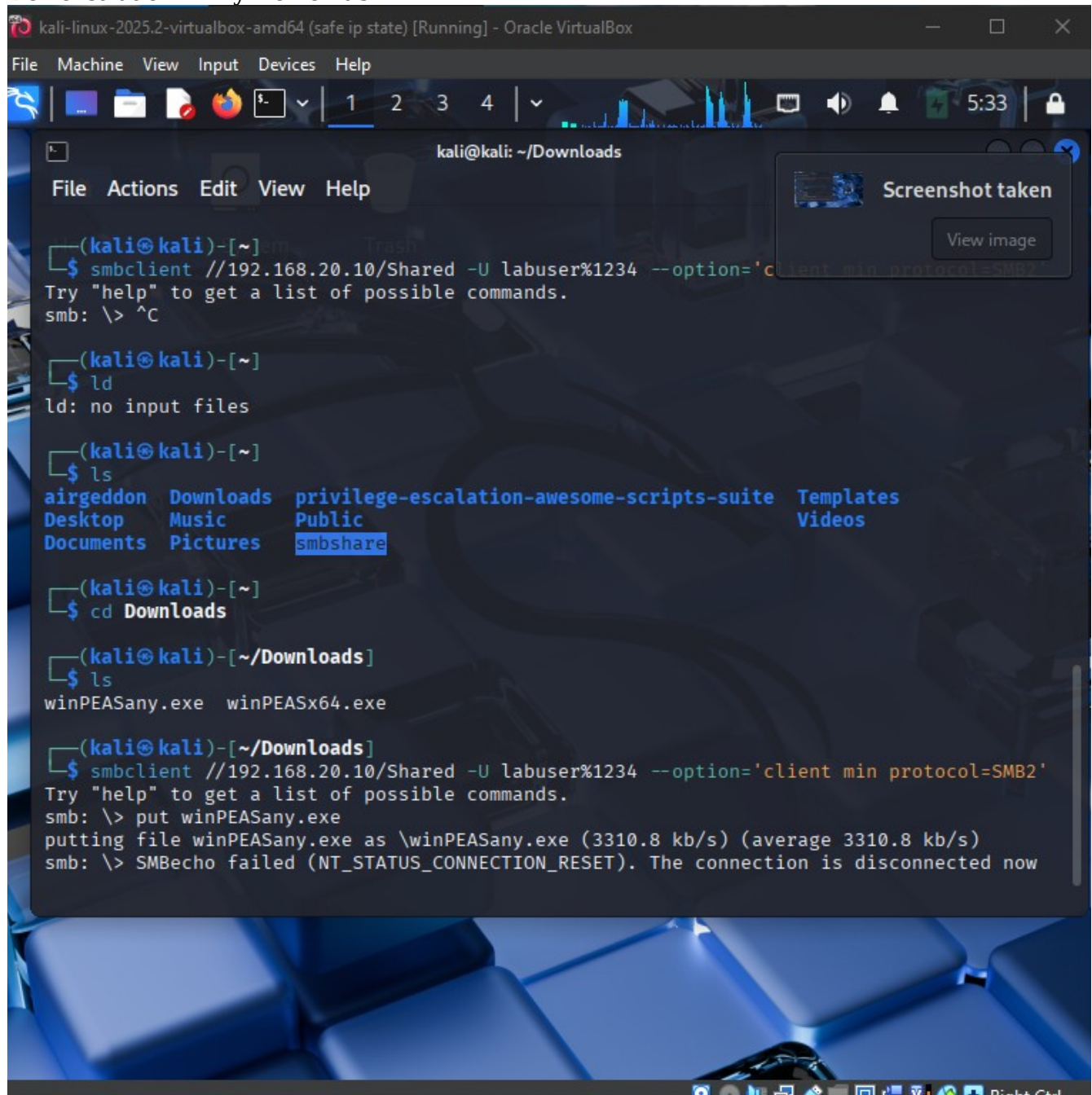
Next Steps

- Use tools like Process Explorer, tasklist, or Autoruns to identify execution paths.
- Deploy a reverse shell or privilege escalation payload.

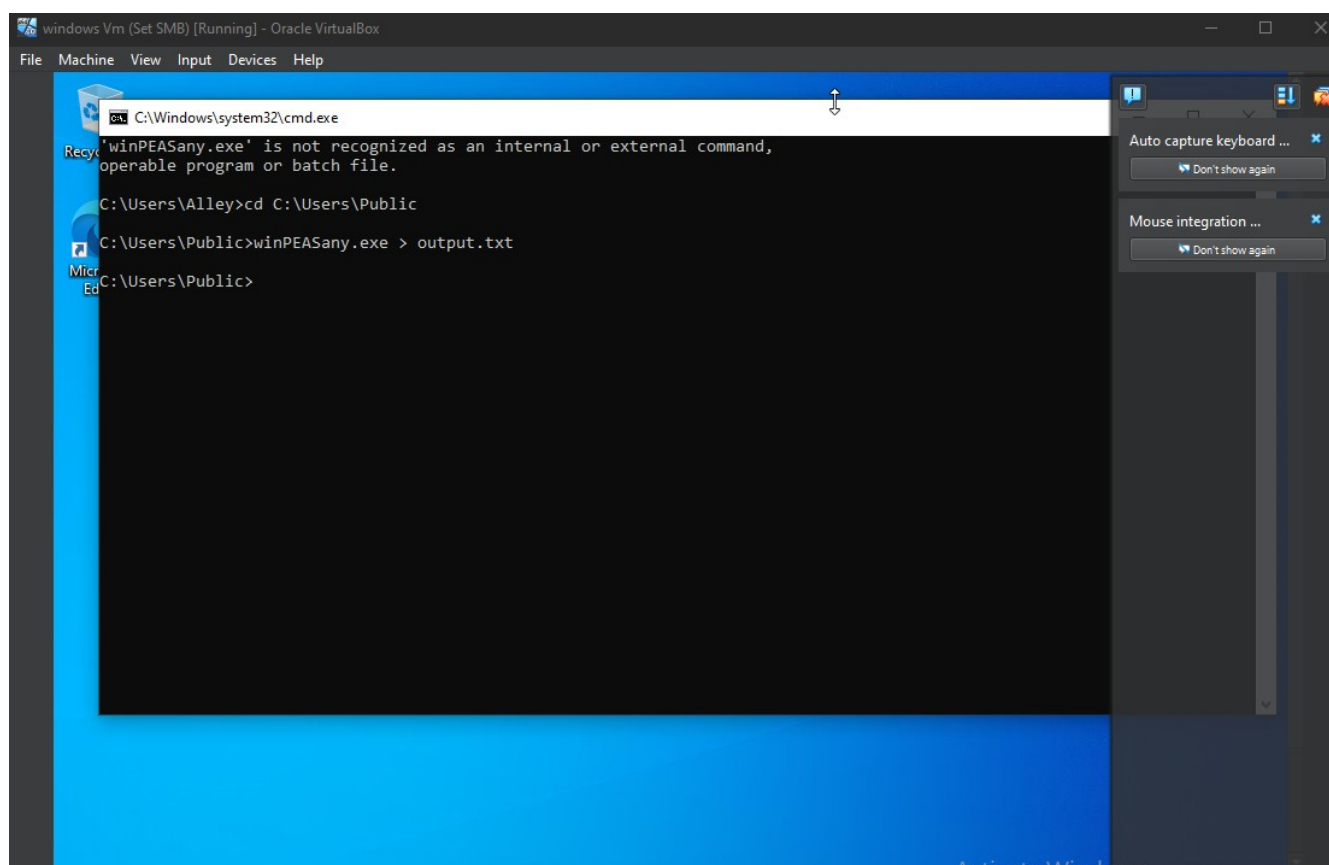
NB: For Education Purposes Only

- Document and validate successful escalation.

Demonstration in My Home Lab



NB: For Education Purposes Only



What to look for in winPEAS output (prioritized)

1. Plaintext credentials (files, scripts, registry) — immediate priority.
2. Unquoted service paths — classic escalation.
3. Writable service binary paths or services — can lead to SYSTEM.
4. Scheduled tasks running as SYSTEM with writable folders.
5. World-writable files/folders or ACLs that permit code placement.
6. Open shares with write permissions (for lateral movement or payloads).
7. Weak WinRM/RDP configs or missing patches (exploits).

